

Cover Page

(Use Page Break: Insert->Page Break or CTRL+Enter)

Index

Auto generated (References => Table of Contents. Make sure titles are using Headings Style)

The Index shouldn't have / include duplicate entries. In our case, for security reports, because each vulnerability sheet is having the same structure as the others, your Index will have duplicate "indicators of criticality", "description", "exploitation" and "remediation". If this happens, make sure to exclude them from your index.

Secrets hardcoded withing the application....4

~~Indicators of criticality~~ (these should be removed)

~~Description~~

~~Exploitation~~

~~remediation~~

Password changing feature not working.....6

~~Indicators of criticality~~

~~Description~~

~~Exploitation~~

~~remediation~~

...

Synthesis

(50% and + of the page, no screenshot, no technical details, impersonal writing style)

Gross explanation of:

- 1- **The context and scope:** what are you auditing, when and why.
- 2- **Vulnerabilities categories** (critical, medium and low) with explanations about the risk impact on the business.
E.g. 5 critical vulnerabilities allowing the attacker to take the control of the system, read passwords, ...
- 3- **The recommendations** (big lines that the customer needs to follow to fix the vulnerabilities).

Bonus: include a pie chart / graphs related to CVSS criticality scores.

No technical details in the synthesis. This is read by the project manager, that doesn't focus much on technical details, but more on the big picture.

Writing style has to be impersonal (do not use "we", "I", "you", ...).

Vulnerability sheet

Every vulnerability sheet starts at a new page (use Page Breaks)

Every vulnerability sheet must have the following items:

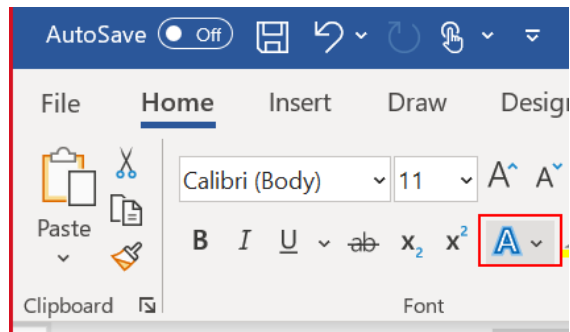
- 1- **Title:** the vulnerability name
- 2- **The Common Weakness Enumeration (CWE) ID** ([CWE - Common Weakness Enumeration \(mitre.org\)](https://cwe.mitre.org/))
- 3- **CVSS 3.1 Base Score Metrics** ([NVD - CVSS v3 Calculator \(nist.gov\)](https://nvd.nist.gov/vuln/calculator)):
 - Lite version of the calculation grid / vector
 - Score
 - Risk level (low, medium, high)
- 4- **Description:**

Short (few lines: 2-7) explaining what the vulnerability (definition) is and what is the business impact on the customer / what will the attacker be able to do.

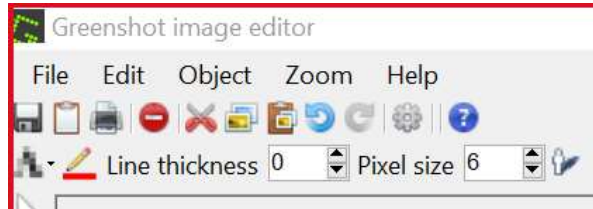
This section doesn't usually require screenshots.
- 5- **Exploitation:**
 - a. Reproduces the required steps to exploit the vulnerability.
 - b. If you are leveraging a software to exploit / demonstrate the vulnerability, mention it and put a reference to it. E.g. "A widely available and open-source password cracking tool like [Openwall John The Ripper](#) can be used to crack these password".
Software like [Wireshark](#) don't have a company name, it's fine to mention them with their proper names.
 - c. Use screenshots for your steps, so the developers can understand how to reproduce the exploitation of this vulnerability and fix it correctly.
 - d. Screenshots software (Windows: [Greenshot](#), [ShareX](#) or the default Snipping Tool. Linux: Shutter, SnapPy, scrot+Gimp, MacOS: native "screenshot" tool or QuickTime)
 - e. Screenshot needs to be in centre of the page (CTRL+E).
 - f. Screenshot must include the window's title bar and is captured from the top left corner of the window



- g. Always resize from image's corners to keep the same width/height ratio
- h. Blur sensitive data (password needs to be blurred at 80%)
- i. Put in a rectangle or point the important data (if too much info in the screenshot)
- j. Don't put screenshots side by side without text between them
- k. Write some text BEFORE and AFTER the image



Some text here is mandatory to explain/introduce the next screenshot:



The text after explains what was seen or introduces the next explanation step.

6- Remediation:

- a. How to fix this issue?
- b. Must be focused on the technology used by the customer. E.g. if the customer uses native C software, no need to give recommendation applicable only to Java. Apache server, no need to give recommendations for nginx server.
- c. If more than one recommendation is possible, prioritize them based on the efficacy and cost.
- d. Always add a reference to an external resource with more [details](#).

Projects folder structure

~/**projects**: root folder for all projects

~/**projects/_customerName**: template folder duplicated and renamed for each project/customer

~/**projects/_customerName/_appName/info.txt**: notes about the scope, contact, app's description, credentials, ...

~/**projects/_customerName/_appName/screenshots**: contains all screenshots from the audit (raw images)

~/**projects/_customerName/_appName/vulnerabilities**: contains one folder per vulnerability (e.g. 01_Cross-Site_Scripting)

~/**projects/_customerName/_appName/vulnerabilities/<id_folder>/**: contains selected screenshots that will be used in the report

~/**projects/_customerName/_appName/report**: contains the report in docx and pdf

~/**projects/_customerName/_appName/others**: has everything else.